PROYECTO · PARTE 1 · DEFENSA ORAL

Diseño del control de acceso para Verdeazul Carbono

Políticas, matriz y arquitectura de seguridad

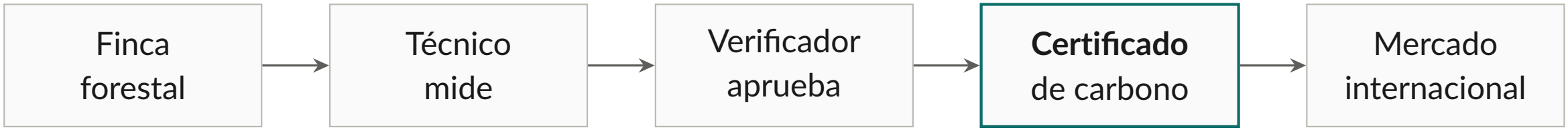
Randall Bolaños **Javier Tenorio** **Julio Varela** **Axel Flores**

Grupo 6 · CE-1115 Seguridad de la Información · Prof. MSc. Andrés Vargas Rivera · ITCR · 15 de octubre de 2026



Reparto propuesto. Randall: cliente, activos y separación de responsabilidades. Javier: amenazas, marco legal, fricción, riesgos residuales y respuestas del cliente. Julio: modelo de control de acceso y matriz. Axel: controles de historial y arquitectura. Todos deben poder responder por cualquier lámina: las preguntas del profesor son individuales.

Verdeazul vende confianza: cada certificado respalda una tonelada real



Un dato inflado es fraude.

Auditores europeos pueden pedir la trazabilidad de cualquier certificado de los últimos diez años.

Verdeazul vende confianza: cada certificado respalda una tonelada real



Qué decir: Verdeazul certifica captura de carbono en fincas forestales. El técnico mide, el verificador aprueba y se emite un certificado que el dueño vende afuera. El valor del certificado es la confianza en el dato. Hoy todo vive en hojas de cálculo compartidas.
Si preguntan por qué empezamos por el negocio: porque el enunciado pide políticas que describan a este cliente, y casi todas las decisiones salen de esta lámina.

Los dos sustos de la carta son fallas de integridad

PRIMER SUSTO	Una medición cambió después de aprobada, y nadie sabe quién fue.
SEGUNDO SUSTO	Un certificado se emitió dos veces sobre la misma hectárea.

Orden de prioridad: **integridad**, confidencialidad, disponibilidad.

Cuando dos pilares chocan, gana la integridad: sin registro en bitácora no hay acción.

Los dos sustos de la carta son fallas de integridad

Los dos sustos de la carta son fallas de integridad

PRIMER SUSTO	Una medición cambió después de aprobada, y nadie sabe quién fue.
SEGUNDO SUSTO	Un certificado se emitió dos veces sobre la misma hectárea.

Orden de prioridad: **integridad**, confidencialidad, disponibilidad.

Cuando dos pilares chocan, gana la integridad: sin registro en bitácora no hay acción.

Qué decir: ninguno de los dos incidentes fue un robo de información. En los dos, el dato dejó de ser confiable. Por eso la integridad va primero. La confidencialidad va segunda por la competencia entre dueños y por los datos personales. La disponibilidad va tercera, con un matiz: importa más que el dato exista en diez años que un día sin sistema.

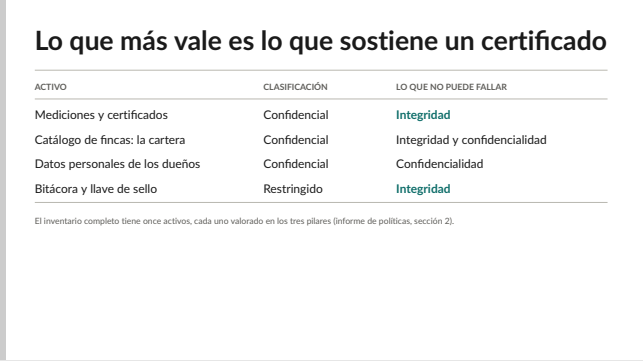
Si preguntan por un ejemplo de «gana la integridad»: si la bitácora no se puede escribir, la operación se rechaza aunque eso detenga el trabajo (POL-BT-06).

Lo que más vale es lo que sostiene un certificado

ACTIVO	CLASIFICACIÓN	LO QUE NO PUEDE FALLAR
Mediciones y certificados	Confidencial	**Integridad**
Catálogo de fincas: la cartera	Confidencial	Integridad y confidencialidad
Datos personales de los dueños	Confidencial	Confidencialidad
Bitácora y llave de sello	Restringido	**Integridad**

El inventario completo tiene once activos, cada uno valorado en los tres pilares (informe de políticas, sección 2).

Lo que más vale es lo que sostiene un certificado



Lo que más vale es lo que sostiene un certificado

ACTIVO	CLASIFICACIÓN	LO QUE NO PUEDE FALLAR
Mediciones y certificados	Confidencial	**Integridad**
Catálogo de fincas: la cartera	Confidencial	Integridad y confidencialidad
Datos personales de los dueños	Confidencial	Confidencialidad
Bitácora y llave de sello	Restringido	**Integridad**

El inventario completo tiene once activos, cada uno valorado en los tres pilares (informe de políticas, sección 2).

Qué decir: clasificamos en cuatro niveles (público, interno, confidencial, restringido) y valoramos cada activo con la escala de FIPS 199. La Gerencia de Certificación es la responsable del dato; el administrador y el operador son custodios.

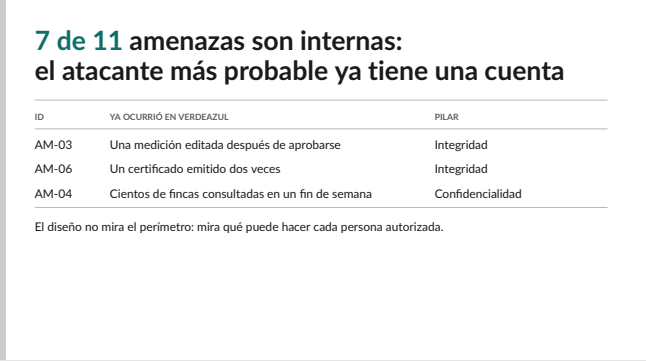
Si preguntan por un activo que no es obvio: los parámetros de cálculo (A-10). Un factor alterado infla todos los certificados a la vez. Y la llave de sello (A-09): quien la tenga fabrica certificados creíbles.

7 de 11 amenazas son internas: el atacante más probable ya tiene una cuenta

ID	YA OCURRIÓ EN VERDEAZUL	PILAR
AM-03	Una medición editada después de aprobarse	Integridad
AM-06	Un certificado emitido dos veces	Integridad
AM-04	Cientos de fincas consultadas en un fin de semana	Confidencialidad

El diseño no mira el perímetro: mira qué puede hacer cada persona autorizada.

7 de 11 amenazas son internas: el atacante más probable ya tiene una cuenta



Qué decir: el modelo tiene once amenazas, cada una con agente, motivo, activo, la debilidad que hoy lo permite y el riesgo. Siete son internas: técnico que infla, misma persona que mide y aprueba, edición silenciosa, extracción de la cartera, administrador u operador que abusa, doble emisión por error y, desde la consulta al cliente, el empleado con un vínculo con un dueño (AM-11): no existe un registro de esos vínculos. Tres ya ocurrieron.

Externas: dueño que quiere ver a un competidor, robo de credenciales, ransomware y certificado falsificado o cuenta de auditor tomada.

Si preguntan cómo calculamos el riesgo: probabilidad por impacto. Probabilidad alta es que ya ocurrió aquí o que es la vía habitual de ataque en el país.

Cada obligación legal termina en una regla que se puede comprobar

NORMA	EXIGE	REGLA EN VERDEAZUL
Ley 8968, art. 14	Autorización para transferir datos	El auditor consulta en la plataforma
Reglamento, art. 38	Avisar una fuga en 5 días hábiles	Procedimiento con ese plazo
Ley 7975, art. 2	Medidas razonables de secreto	Acceso por necesidad y registro
ISO/IEC 17029	Quien revisa no participó	**Medir y aprobar, separados**

El cliente aclaró que no audita bajo una norma determinada: la ISO se cita como referencia. Su exigencia firme es la trazabilidad de diez años.

Cada obligación legal termina en una regla que se puede comprobar

Cada obligación legal termina en una regla que se puede comprobar

NORMA	EXIGE	REGLA EN VERDEAZUL
Ley 8968, art. 14	Autorización para transferir datos	El auditor consulta en la plataforma
Reglamento, art. 38	Avisar una fuga en 5 días hábiles	Procedimiento con ese plazo
Ley 7975, art. 2	Medidas razonables de secreto	Acceso por necesidad y registro
ISO/IEC 17029	Quien revisa no participó	**Medir y aprobar, separados**

El cliente aclaró que no audita bajo una norma determinada: la ISO se cita como referencia. Su exigencia firme es la trazabilidad de diez años.

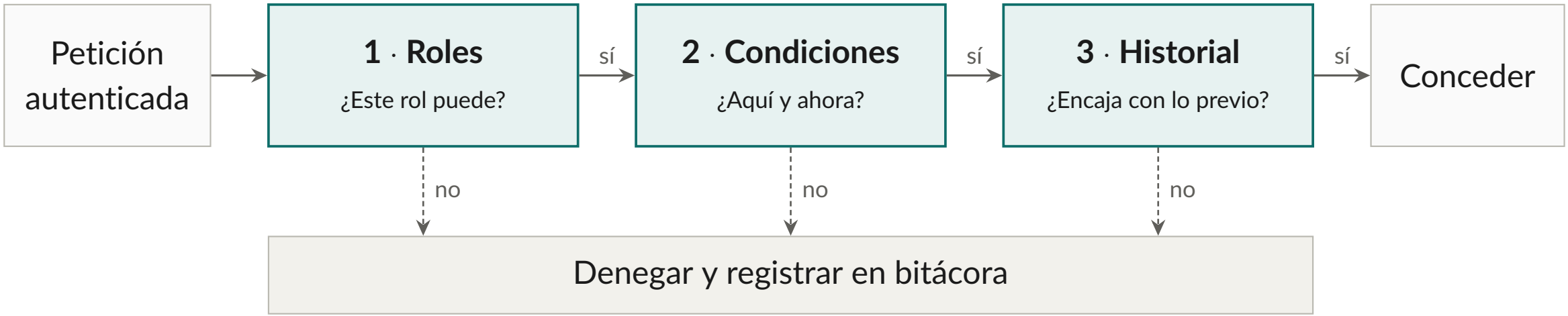
Qué decir: la Ley 8968 aplica porque los datos de los dueños se comparten con auditores externos; no es una base de uso exclusivamente interno. Derechos del titular en cinco días hábiles; consentimiento informado al dar de alta a un dueño; conservación hasta diez años y después se desasocia.

La Ley 7975 es la que permite reclamar si la cartera llega a la competencia, pero solo si la empresa puede demostrar que tomó medidas razonables: por eso el acceso por asignación y la bitácora tienen además valor legal.

También: Código Penal (arts. 196 bis, 217 bis, 229 bis y 231), Código de Trabajo art. 71 g) y Ley 8454 de firma digital.

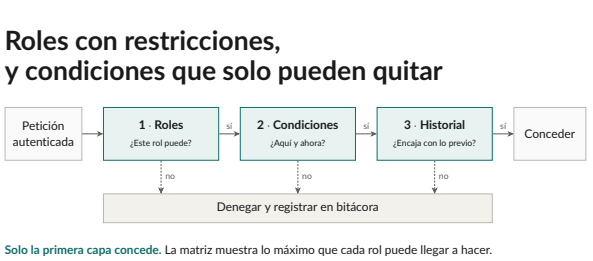
Auditores, según la minuta (P-18): una vez al año, varios días, en sitio o a distancia. Pueden exportar evidencia, pero como paquetes que genera el sistema, sellados, registrados y sin datos personales. El acceso vence con la ventana autorizada; prorrogarlo es una autorización nueva.

Roles con restricciones,
y condiciones que solo pueden quitar



Solo la primera capa concede. La matriz muestra lo máximo que cada rol puede llegar a hacer.

Roles con restricciones, y condiciones que solo pueden quitar



Qué decir: elegimos RBAC con restricciones, nivel RBAC2 de Sandhu. Sobre esa base, un conjunto cerrado de atributos decide si el permiso aplica a esta finca, en este estado y en este momento. Es el enfoque centrado en roles de Kuhn, Coyne y Weil.

La frontera del híbrido: la capa 1 dice si el rol tiene el verbo; la capa 2 si aplica a este objeto ahora; la capa 3 si encaja con el historial. Se combinan sin contradecirse porque solo la tabla de roles concede y las otras dos son filtros: una negativa en cualquier capa gana.

Si preguntan por qué RBAC: la carta describe funciones, no personas; la gente rota; y hay que poder explicarlo a un auditor leyendo una fila.

Los otros tres modelos fallan por razones de este caso

MODELO	POR QUÉ NO EN VERDEAZUL
DAC	Es lo que hay hoy: las hojas compartidas donde ocurrieron los dos sustos.
MAC	No hay niveles de secreto. Haría falta un compartimento por finca.
ABAC puro	Desaparece la fila que responde «¿qué puede hacer un verificador?».

De cada uno se conserva algo: la titularidad como atributo (DAC), la política que el usuario no puede alterar (MAC) y las condiciones acotadas (ABAC).

Los otros tres modelos fallan por razones de este caso



Los otros tres modelos fallan por razones de este caso

MODELO	POR QUÉ NO EN VERDEAZUL
DAC	Es lo que hay hoy: las hojas compartidas donde ocurrieron los dos sustos.
MAC	No hay niveles de secreto. Haría falta un compartimento por finca.
ABAC puro	Desaparece la fila que responde «¿qué puede hacer un verificador?».

De cada uno se conserva algo: la titularidad como atributo (DAC), la política que el usuario no puede alterar (MAC) y las condiciones acotadas (ABAC).

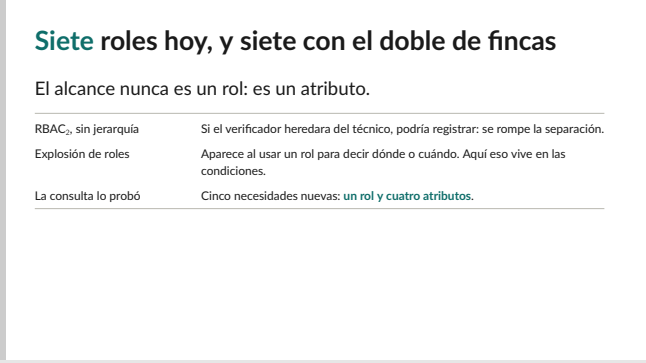
DAC: el técnico que crea la medición sería su dueño y podría seguir modificándola o compartirla. Es el primer susto.
MAC: Bell-LaPadula ordena por niveles de secreto y protege la confidencialidad. Aquí el riesgo principal es de integridad. La variante de integridad, Biba, pone una etiqueta fija, pero la confianza en una medición cambia con su estado y depende de quién hizo el paso anterior. Es el argumento de Clark y Wilson. MAC sí lo usamos en la plataforma: SELinux confina los contenedores.
ABAC puro: podría expresarlo todo, pero no se puede revisar leyendo una fila, y la empresa no tiene quién gobierne un catálogo de atributos.

Siete roles hoy, y siete con el doble de fincas

El alcance nunca es un rol: es un atributo.

$RBAC_2$, sin jerarquía	Si el verificador heredara del técnico, podría registrar: se rompe la separación.
Explosión de roles	Aparece al usar un rol para decir dónde o cuándo. Aquí eso vive en las condiciones.
La consulta lo probó	Cinco necesidades nuevas: **un rol y cuatro atributos**.

Siete roles hoy, y siete con el doble de fincas



Los siete roles: técnico, verificador, supervisor de campo, gerencia de certificación, administrador de catálogo y cuentas, auditor externo y dueño de finca. Más una identidad de servicio (SIS), el operador de plataforma, que no tiene rol en la aplicación, y el público sin autenticar.

El séptimo rol salió de la consulta: el cliente dijo que las fincas las asignan los supervisores del personal de campo (minuta, P-05). Las otras cuatro necesidades nuevas (el verificador que mide por excepción, el técnico que apoya a un compañero, la sociedad con un representante y el empleado con un vínculo con un dueño) no son funciones de trabajo: se resolvieron con atributos.

Por qué RBAC2 y no RBAC3: no hay cadena de mando entre las siete funciones; la herencia vuelve implícitos los permisos y la matriz no debe tener nada implícito; y con siete roles no ahorra nada.

Restricciones: un rol por persona, una identidad por persona, al menos dos verificadores, cuenta de auditor con ventana. La pareja técnico–verificador es la única excepción: es dinámica. Un verificador puede recibir una habilitación temporal de técnico, con fecha de fin, y nunca aprueba lo que midió (minuta, P-01).

Si preguntan dónde está el riesgo de explosión: un rol por finca para aislar a los dueños, o roles como «Técnico Zona Sur 2027».

Cuatro controles de historial, uno de cada tipo

	TIPO	QUÉ LO DISPARA	QUÉ DECIDE
H1	Frecuencia	Muchas fincas distintas en un día	**Tres niveles**: avisa, confirma, restringe
H2	Tiempo	Una decisión fuera de jornada	Pide segundo factor y motivo
H3	Combinada	Fuera de jornada, muchas fincas, casi todas nuevas	Confirma y avisa; si insiste, restringe
H4	Secuencia	Quien participó antes quiere decidir	**Deniega**

Ninguna señal aislada restringe: el cliente pidió avisar primero y no bloquear de inmediato (minuta, P-10).

Cuatro controles de historial, uno de cada tipo

Cuatro controles de historial, uno de cada tipo

	TIPO	QUÉ LO DISPARA	QUÉ DECIDE
H1	Frecuencia	Muchas fincas distintas en un día	**Tres niveles:** avisa, confirma, restringe
H2	Tiempo	Una decisión fuera de jornada	Pide segundo factor y motivo
H3	Combinada	Fuera de jornada, muchas fincas, casi todas nuevas	Confirma y avisa; si insiste, restringe
H4	Secuencia	Quien participó antes quiere decidir	**Deniega**

Ninguna señal aislada restringe: el cliente pidió avisar primero y no bloquear de inmediato (minuta, P-10).

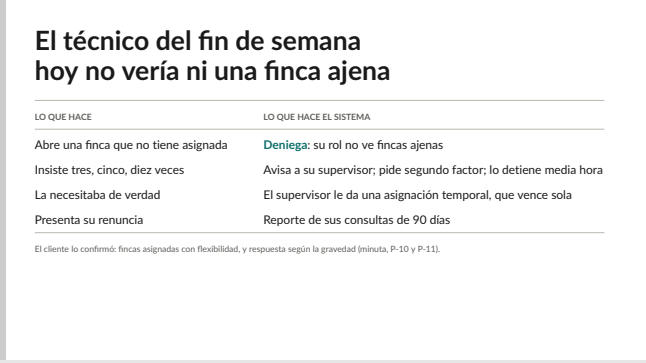
Son reglas explícitas, no aprendizaje automático: se le pueden leer a un auditor y se pueden probar.
Cómo se distingue lo legítimo: se cuentan señales: volumen, novedad, momento e insistencia. El trabajo extraordinario legítimo muestra una; la extracción de la cartera las muestra juntas.
Tres niveles: aviso (el usuario no nota nada), verificación adicional (segundo factor y motivo) y restricción temporal (no abre fincas nuevas hasta el siguiente día hábil; la cuenta sigue activa).
H1 mitiga AM-04. Umbrales por rol, calibrados con datos reales; iniciales 40, 60 y 80 fincas por día (supuesto P-13). Los intentos denegados cuentan doble.
H2 mitiga AM-08, la cuenta robada usada de madrugada. H4 es la separación de responsabilidades como control de historial: reglas C3, C8 y C10.
H3 es la firma del incidente: fin de semana, cientos de fincas, ninguna suya. Pide confirmación en la finca once y avisa; restringe en la veintiuna.
Falsos positivos: verificador con la cola acumulada al cierre, o nuevo y sin historial. El primer período corre en observación para calibrar.
Descartada: Muralla China. Todos los dueños compiten: cada empleado quedaría con una sola finca.

El técnico del fin de semana hoy no vería ni una finca ajena

LO QUE HACE	LO QUE HACE EL SISTEMA
Abre una finca que no tiene asignada	**Deniega**: su rol no ve fincas ajenas
Insiste tres, cinco, diez veces	Avisa a su supervisor; pide segundo factor; lo detiene media hora
La necesitaba de verdad	El supervisor le da una asignación temporal, que vence sola
Presenta su renuncia	Reporte de sus consultas de 90 días

El cliente lo confirmó: fincas asignadas con flexibilidad, y respuesta según la gravedad (minuta, P-10 y P-11).

El técnico del fin de semana hoy no vería ni una finca ajena



El técnico del fin de semana hoy no vería ni una finca ajena

LO QUE HACE	LO QUE HACE EL SISTEMA
Abre una finca que no tiene asignada	**Deniega:** su rol no ve fincas ajenas
Insiste tres, cinco, diez veces	Avisa a su supervisor; pide segundo factor; lo detiene media hora
La necesitaba de verdad	El supervisor le da una asignación temporal, que vence sola
Presenta su renuncia	Reporte de sus consultas de 90 días

El cliente lo confirmó: fincas asignadas con flexibilidad, y respuesta según la gravedad (minuta, P-10 y P-11).

Qué decir: la carta dice «no sabemos qué hacer con eso, pero nos gustaría que el sistema al menos se diera cuenta». Nuestra primera respuesta no es vigilar el permiso: es quitarlo. Un técnico solo ve las fincas que tiene asignadas (regla C1).

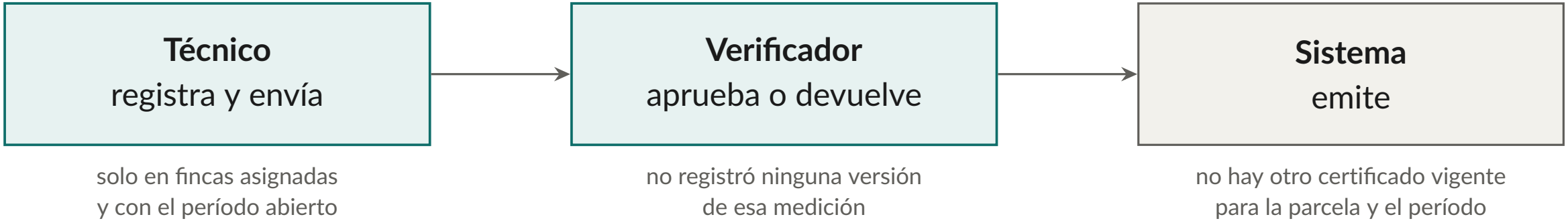
El cliente lo confirmó, con una condición: flexibilidad para apoyar a un compañero, sustituir a un ausente o atender una visita extraordinaria, sin acceso permanente a todas las fincas. Se resuelve con asignaciones temporales que crea el supervisor de campo, con motivo y fecha de fin (regla C19).

El diseño original suspendía la sesión a la quinta denegación. El cliente pidió no bloquear de inmediato, y se cambió: aviso al supervisor a la tercera, segundo factor a la quinta, media hora de restricción a la décima.

Los controles de historial quedan para quienes sí necesitan leer muchas fincas: verificador, supervisor, gerencia, administrador y auditor. Si el técnico hubiera sido verificador, H3 le pide confirmación en la finca once y lo restringe en la veintiuna.

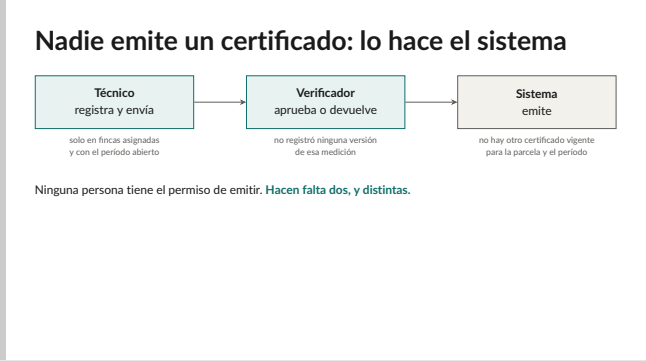
Además hay una vía legal: confidencialidad firmada, que persiste después de la salida (Ley 8968 art. 11 y Ley 7975).

Nadie emite un certificado: lo hace el sistema



Ninguna persona tiene el permiso de emitir. **Hacen falta dos, y distintas.**

Nadie emite un certificado: lo hace el sistema



La acción crítica: emitir un certificado. Si una sola persona pudiera medir y aprobar, podría inflar la biomasa, aprobar su propio dato y obtener un certificado por toneladas que no existen.

La segunda acción crítica: corregir una medición ya congelada. Es el primer susto, y se trata igual, con el orden que pidió el cliente (minuta, P-07): solicita el técnico responsable, un verificador o la Gerencia; corrige el técnico; revisa un verificador que no es autor ni solicitante; y la Gerencia da la autorización final. Son al menos tres personas.

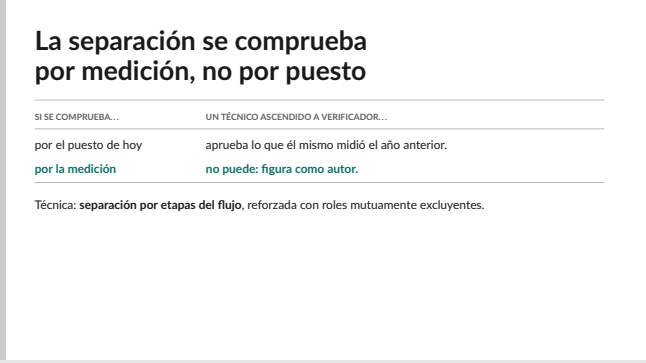
Si preguntan qué pasa con el certificado tras una enmienda (minuta, P-08): si las toneladas no cambian, sigue vigente con la enmienda anotada. Si cambian, el sistema lo revoca y emite el reemplazo en un solo acto, enlazados: nunca hay dos vigentes y ninguno se borra. Si ya se vendió, la Gerencia lo registra y coordina con las partes.

La separación se comprueba por medición, no por puesto

SI SE COMPRUEBA…	UN TÉCNICO ASCENDIDO A VERIFICADOR…
por el puesto de hoy	aprueba lo que él mismo midió el año anterior.
por la medición	**no puede: figura como autor.**

Técnica: **separación por etapas del flujo**, reforzada con roles mutuamente excluyentes.

La separación se comprueba por medición, no por puesto



Qué decir: quien inicia el proceso no puede cerrarlo. El sistema no pregunta qué rol tiene la persona, pregunta si participó en esta medición. En la literatura es la separación basada en el objeto o en el historial (Nash y Poland 1990; Simon y Zurko 1997).

Por qué es la adecuada: apunta al riesgo tal como lo dijo el cliente; sobrevive a los cambios de puesto (la lección de Kerviel); no depende de que los roles estén bien administrados; y deja dos nombres distintos en cada certificado.

El cliente confirmó que algunos verificadores fueron técnicos y que por excepción pueden medir, y pidió «garantizar una revisión independiente, sin impedir que el personal pueda asumir otras responsabilidades» (minuta, P-01). Una separación por puesto obligaría a escoger; esta da las dos cosas: el verificador mide con una habilitación temporal y no podrá aprobar nunca lo que midió.

Coincide con el principio de imparcialidad de ISO/IEC 17029, que citamos solo como referencia.

Las alternativas se descartaron por lo que cuestan aquí

TÉCNICA	POR QUÉ NO ES LA PRINCIPAL
Roles excluyentes, solos	No cubren a quien cambia de puesto
Doble control (cuatro ojos)	**Duplica la verificación de cada certificado**
Segregación temporal	Limita cuándo, no quién
Rotación	No impide un acto; se recomienda contra la colusión

La segregación temporal sí se usa donde el problema es la duración: la asignación temporal, la habilitación del verificador, el plazo de la enmienda y la cuenta del auditor.

Las alternativas se descartaron por lo que cuestan aquí

Las alternativas se descartaron por lo que cuestan aquí

TÉCNICA	POR QUÉ NO ES LA PRINCIPAL
Roles excluyentes, solos	No cubren a quien cambia de puesto
Doble control (cuatro ojos)	**Duplica la verificación de cada certificado**
Segregación temporal	Limita cuándo, no quién
Rotación	No impide un acto; se recomienda contra la colusión

La segregación temporal sí se usa donde el problema es la duración: la asignación temporal, la habilitación del verificador, el plazo de la enmienda y la cuenta del auditor.

Roles mutuamente excluyentes estáticos (RBAC2): se conservan como refuerzo. Li, Tripunitara y Bizri muestran que excluir roles es un mecanismo para aproximar la separación, no la separación misma.

Exclusión dinámica: basta cerrar sesión y abrir otra. Sola, demora el fraude y no lo impide. Se usa como refuerzo en la pareja técnico–verificador, detrás de la regla C3.

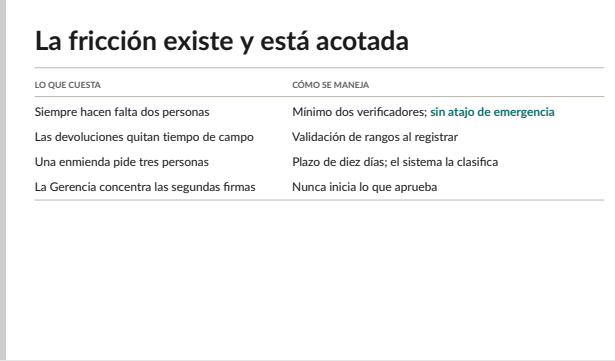
Doble control: era la opción más fuerte contra el fraude. Se descartó por costo operativo: duplica la verificación de cada certificado, con cualquier tamaño de equipo.

Rotación: cuesta conocimiento de la finca y depende de cuántas personas haya, un dato que el cliente pidió no fijar (minuta, P-02).

La fricción existe y está acotada

LO QUE CUESTA	CÓMO SE MANEJA
Siempre hacen falta dos personas	Mínimo dos verificadores; **sin atajo de emergencia**
Las devoluciones quitan tiempo de campo	Validación de rangos al registrar
Una enmienda pide tres personas	Plazo de diez días; el sistema la clasifica
La Gerencia concentra las segundas firmas	Nunca inicia lo que aprueba

La fricción existe y está acotada



Qué decir: no existe un atajo para aprobar lo propio. Un atajo así sería el hueco que el auditor buscaría. Si el único verificador presente participó, la medición espera; la cola avisa a la Gerencia.

Lo que la técnica no resuelve: la colusión. Si un técnico y un verificador se ponen de acuerdo, el flujo se cumple. La separación sube el costo del fraude de una persona a dos. Quedan la rotación, un indicador de parejas repetidas y la auditoría externa.

La Gerencia es un cuello de botella y un punto de confianza: firma en varios flujos, pero nunca inicia lo que aprueba, no registra ni aprueba mediciones, ya no asigna fincas y no resuelve sus propias alertas.

Enmienda: revisa un verificador distinto del original solo cuando es material (cambia toneladas o ya hay certificado); lo determina el sistema. Con solo dos verificadores, si uno solicita sobre lo que aprobó el otro no queda revisor: la presenta el técnico o la Gerencia.

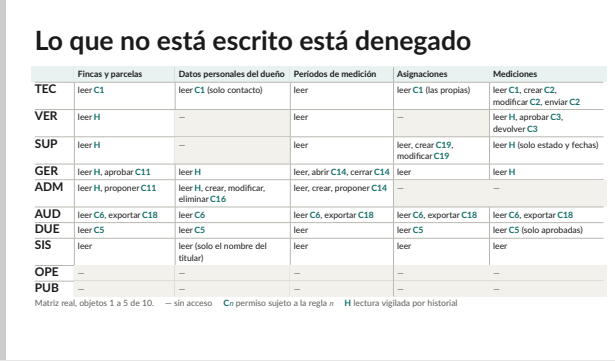
La flexibilidad también cuesta un trámite: la asignación temporal la crea el supervisor y la habilitación de un verificador para medir pasa por el administrador y la Gerencia.

Lo que no está escrito está denegado

	Fincas y parcelas	Datos personales del dueño	Períodos de medición	Asignaciones	Mediciones
TEC	leer C1	leer C1 (solo contacto)	leer	leer C1 (las propias)	leer C1, crear C2, modificar C2, enviar C2
VER	leer H	—	leer	—	leer H, aprobar C3, devolver C3
SUP	leer H	—	leer	leer, crear C19, modificar C19	leer H (solo estado y fechas)
GER	leer H, aprobar C11	leer H	leer, abrir C14, cerrar C14	leer	leer H
ADM	leer H, proponer C11	leer H, crear, modificar, eliminar C16	leer, crear, proponer C14	—	—
AUD	leer C6, exportar C18	leer C6	leer C6, exportar C18	leer C6, exportar C18	leer C6, exportar C18
DUE	leer C5	leer C5	leer	leer C5	leer C5 (solo aprobadas)
SIS	leer	leer (solo el nombre del titular)	leer	leer	leer
OPE	—	—	—	—	—
PUB	—	—	—	—	—

Matriz real, objetos 1 a 5 de 10. — sin acceso C*n* permiso sujeto a la regla *n* H lectura vigilada por historial

Lo que no está escrito está denegado



Lo que no está escrito está denegado

	Fincas y parcelas	Datos personales del dueño	Períodos de medición	Asignaciones	Mediciones
TEC	leer C1	leer C1 (solo contacto)	leer	leer C1 (las propias)	leer C1, crear C2, modificar C2, enviar C2
VER	leer H	—	leer	—	leer H, aprobar C3, devolver C3
SUP	leer H	—	leer	leer, crear C19, modificar C19	leer H (solo estado y fechas)
GER	leer H, aprobar C11	leer H	leer, abrir C14, cerrar C14	leer	leer H
ADM	leer H, proponer C11	leer H, crear, modificar, eliminar C16	leer, crear, proponer C14	—	—
AUD	leer C6, exportar C18	leer C6	leer C6, exportar C18	leer C6, exportar C18	leer C6, exportar C18
DUE	leer C5	leer C5	leer	leer C5	leer C5 (solo aprobadas)
SIS	leer	leer (solo el nombre del titular)	leer	leer	leer
OPE	—	—	—	—	—
PUB	—	—	—	—	—

Matriz real, objetos 1 a 5 de 10. — sin acceso C*n* permiso sujeto a la regla *n* H lectura vigilada por historial

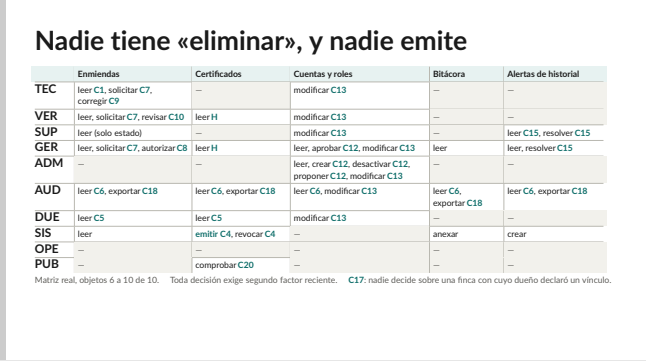
Cómo leerla: sujetos en las filas, objetos en las columnas. Una celda gris es sin acceso. Una marca C significa que el permiso solo vale si se cumple esa regla; las condiciones solo pueden quitar.
Recorrido sugerido: fila TEC, columna Mediciones: crea, modifica y envía, pero no aprueba. Fila VER: aprueba y devuelve con C3, no crea ni modifica, y no ve los datos personales del dueño. Fila SUP, que es nueva: asigna fincas (C19) y de las mediciones solo ve estado y fechas. Fila GER: abre y cierra períodos que registró el administrador (C14); ya no crea asignaciones. Fila AUD: leer y exportar evidencia, con ventana (C6 y C18), y ningún verbo de escritura. Fila DUE: solo lo suyo (C5). Filas OPE y PUB: nada en esta mitad.
Diez sujetos: siete roles, el sistema, el operador y el público sin autenticar.
Mínimo privilegio: cada permiso amplio tiene su justificación en la sección 6 del documento de la matriz.

Nadie tiene «eliminar», y nadie emite

	Enmiendas	Certificados	Cuentas y roles	Bitácora	Alertas de historial
TEC	leer C1, solicitar C7, corregir C9	—	modificar C13	—	—
VER	leer, solicitar C7, revisar C10	leer H	modificar C13	—	—
SUP	leer (solo estado)	—	modificar C13	—	leer C15, resolver C15
GER	leer, solicitar C7, autorizar C8	leer H	leer, aprobar C12, modificar C13	leer	leer, resolver C15
ADM	—	—	leer, crear C12, desactivar C12, proponer C12, modificar C13	—	—
AUD	leer C6, exportar C18	leer C6, exportar C18	leer C6, modificar C13	leer C6, exportar C18	leer C6, exportar C18
DUE	leer C5	leer C5	modificar C13	—	—
SIS	leer	emitir C4, revocar C4	—	anexar	crear
OPE	—	—	—	—	—
PUB	—	comprobar C20	—	—	—

Matriz real, objetos 6 a 10 de 10. Toda decisión exige segundo factor reciente. **C17**: nadie decide sobre una finca con cuyo dueño declaró un vínculo.

Nadie tiene «eliminar», y nadie emite



Nadie tiene «eliminar», y nadie emite

	Enmiendas	Certificados	Cuentas y roles	Bitácora	Alertas de historial
TEC	leer C1, solicitar C7, corregir C9	–	modificar C13	–	–
VER	leer, solicitar C7, revisar C10	leer H	modificar C13	–	–
SUP	leer (solo estado)	–	modificar C13	–	leer C15, resolver C15
GER	leer, solicitar C7, autorizar C8	leer H	leer, aprobar C12, modificar C13	leer	leer, resolver C15
ADM	–	–	leer, crear C12, desactivar C12, proponer C12, modificar C13	–	–
AUD	leer C6, exportar C18	leer C6, exportar C18	leer C6, modificar C13	leer C6, exportar C18	leer C6, exportar C18
DUE	leer C5	leer C5	modificar C13	–	–
SIS	leer	emitir C4, revocar C4	–	anexar	crear
OPE	–	–	–	–	–
PUB	–	comprobar C20	–	–	–

Matriz real, objetos 6 a 10 de 10. Toda decisión exige segundo factor reciente. C17: nadie decide sobre una finca con cuyo dueño declaró un vínculo.

Dos cosas que se ven en esta mitad. Una: el verbo «eliminar» no aparece en enmiendas, certificados, cuentas ni bitácora. Nada se borra; todo cambio es una versión nueva o un cambio de estado. Dos: «emitir» solo está en la fila SIS. Ninguna fila de persona lo tiene.

Columna Enmiendas: solicitar (técnico, verificador o Gerencia), corregir (técnico), revisar (verificador) y autorizar (Gerencia), con las reglas C7 a C10. Cuatro pasos, al menos tres personas.

Columna Cuentas y roles: C13 es «credenciales y declaración propias»; C12 es «nadie se administra a sí mismo»: el administrador propone el rol y la Gerencia lo aprueba.

Columna Bitácora: solo se agrega. La leen la Gerencia y el auditor.

Fila PUB: quien tenga el código de un certificado comprueba si es auténtico y si sigue vigente, y nada más (C20). Sale de la respuesta del cliente sobre autenticidad y estado del certificado (minuta, P-04).

C17, abstención por vínculo: quien declaró un vínculo familiar o comercial con un dueño no mide, no aprueba, no asigna ni autoriza nada sobre esa finca (minuta, P-15).

Al lado de la matriz hay una tabla de exclusiones: cada persona tiene un solo rol, salvo la habilitación temporal de un verificador como técnico.

Tres celdas bastan para leer la separación

	MEDICIONES	CERTIFICADOS
TEC	Crea, modifica y envía. Solo sus borradores, con el período abierto.	Sin acceso
VER	**Aprueba solo si no registró ninguna versión.**	Lee
SIS	Lee	**Emite solo si no hay otro vigente.**

Caso de prueba T-06: la verificadora que antes fue técnica intenta aprobar una medición que registró. Resultado esperado: deniega.

Tres celdas bastan para leer la separación

Tres celdas bastan para leer la separación

	MEDICIONES	CERTIFICADOS
TEC	Crea, modifica y envía. Solo sus borradores, con el período abierto.	Sin acceso
VER	**Aprueba solo si no registró ninguna versión.**	Lee
SIS	Lee	**Emite solo si no hay otro vigente.**

Caso de prueba T-06: la verificadora que antes fue técnica intenta aprobar una medición que registró. Resultado esperado: deniega.

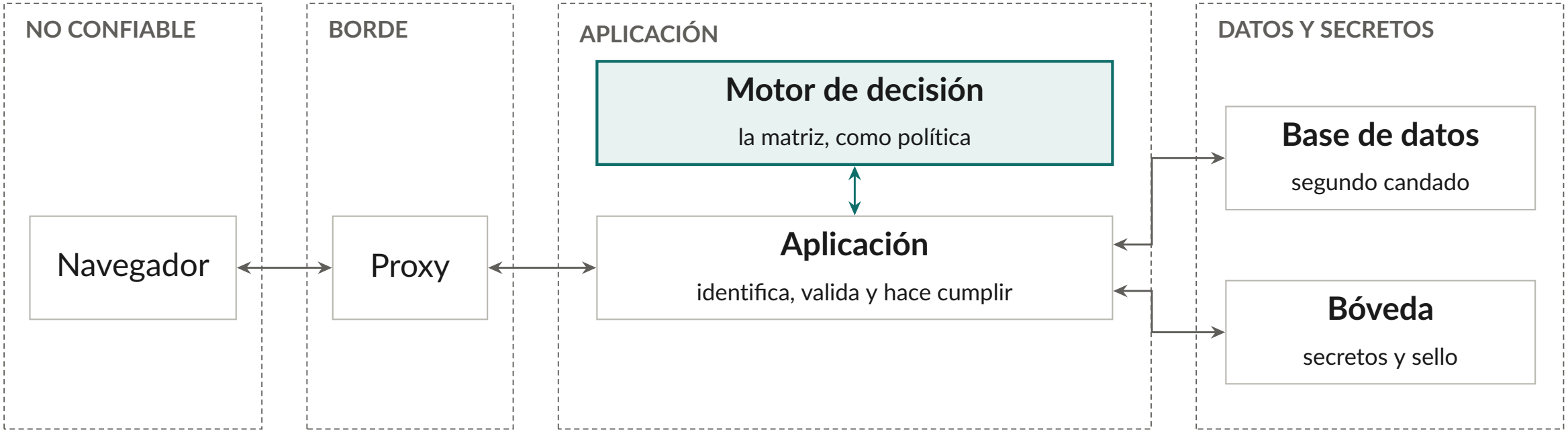
Son las reglas C2, C3 y C4. Cada regla de la matriz tiene un caso de prueba con resultado esperado: treinta y siete casos, T-01 a T-37. El equipo que construya debe convertirlos en pruebas automáticas, más una por cada celda sin acceso.

Otros casos para citar: T-07, segunda emisión sobre la misma parcela y período: no emite. T-08, el dueño cambia el identificador en la dirección: deniega y responde «no encontrado». T-10, el auditor envía una petición de modificación: deniega.

Caso nuevo para citar: T-17, después del cierre el verificador aprueba una medición que se envió a tiempo: concede. El cliente pidió distinguir registrar, modificar, revisar y aprobar (minuta, P-06).

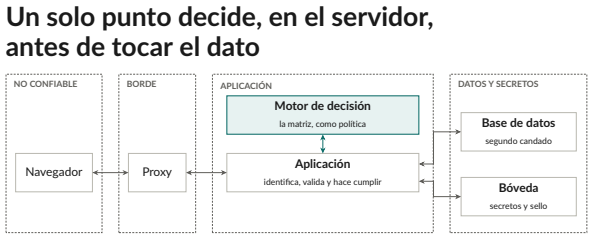
El mismo patrón, quien inicia no cierra, se repite en enmiendas (C7 a C10), períodos (C14), asignaciones (C19), catálogo (C11) y cuentas (C12).

Un solo punto decide, en el servidor, antes de tocar el dato



Esconder un botón no es autorización. Si el servidor no decide, cualquiera llama directo.

Un solo punto decide, en el servidor, antes de tocar el dato



Flujo de una petición: el proxy termina la conexión cifrada; la aplicación identifica la sesión, valida la forma de los datos y lee de la base los hechos; entrega al motor el sujeto, la acción, el objeto y esos hechos; el motor devuelve la decisión con la regla que la determinó. Solo entonces se toca el dato, en una transacción que también escribe la bitácora. La base aplica sus propias restricciones.

Fronteras de confianza: nada de lo que llega del navegador se da por bueno; los hechos se toman de la base, nunca de la petición; si el motor no responde, se deniega; la base no confía en la aplicación.

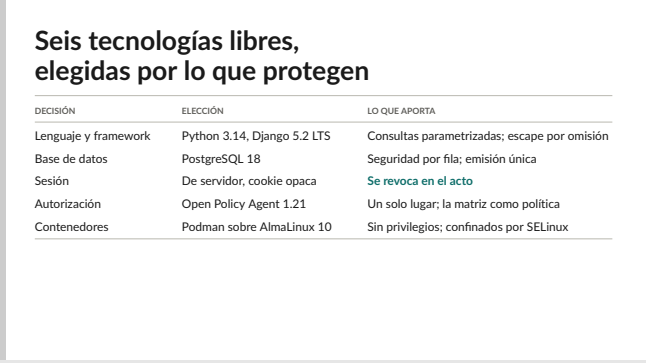
Si preguntan qué pasa si el control está solo en la interfaz: el técnico envía a mano la petición de aprobar su propia medición y el servidor la ejecuta. Es el error de referencia directa a objetos de la clase 13.

Hospedaje, que el cliente dejó a nuestro criterio (minuta, P-23): un servidor virtual contratado, operado por personal que la empresa designe. Hay además una ruta pública de solo lectura para comprobar certificados.

Seis tecnologías libres, elegidas por lo que protegen

DECISIÓN	ELECCIÓN	LO QUE APORTA
Lenguaje y framework	Python 3.14, Django 5.2 LTS	Consultas parametrizadas; escape por omisión
Base de datos	PostgreSQL 18	Seguridad por fila; emisión única
Sesión	De servidor, cookie opaca	**Se revoca en el acto**
Autorización	Open Policy Agent 1.21	Un solo lugar; la matriz como política
Contenedores	Podman sobre AlmaLinux 10	Sin privilegios; confinados por SELinux

Seis tecnologías libres, elegidas por lo que protegen



Seis tecnologías libres, elegidas por lo que protegen

DECISIÓN	ELECCIÓN	LO QUE APORTA
Lenguaje y framework	Python 3.14, Django 5.2 LTS	Consultas parametrizadas; escape por omisión
Base de datos	PostgreSQL 18	Seguridad por fila; emisión única
Sesión	De servidor, cookie opaca	Se revoca en el acto
Autorización	Open Policy Agent 1.21	Un solo lugar; la matriz como política
Contenedores	Podman sobre AlmaLinux 10	Sin privilegios; confinados por SELinux

Para cada una el documento indica versión, alternativas descartadas, aporte, limitaciones y herramientas de análisis.

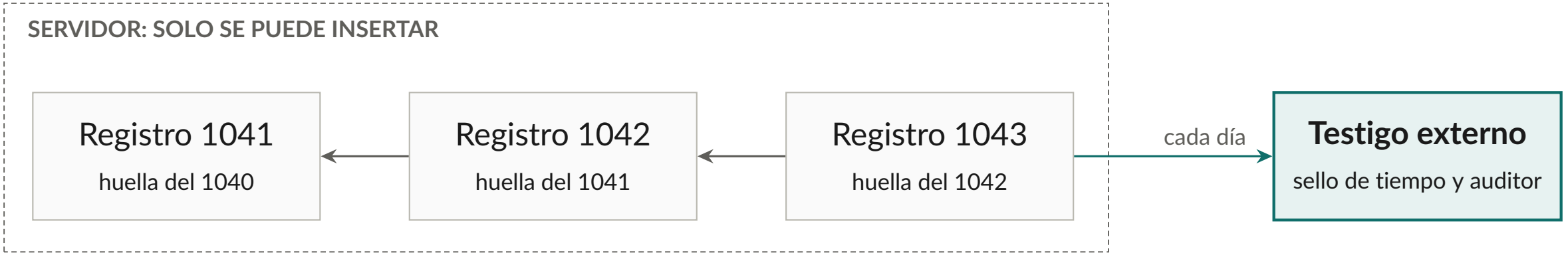
Descartes por licencia: HashiCorp Vault (BUSL desde 2023) y Docker Desktop. Se usa OpenBao, que es software libre.

Descartes por seguridad: tokens JWT, porque no se pueden revocar en el acto al dar de baja o cambiar de rol; MariaDB, porque no tiene seguridad por fila; Docker Engine, por su servicio con privilegios; una cadena de bloques, porque resuelve la desconfianza entre organizaciones, que aquí no existe.

Limitaciones que hay que saber decir: los permisos de Django son por tipo de objeto, no por objeto; su sitio de administración no se instala; el superusuario de PostgreSQL se salta todo; el motor no conoce el historial y no filtra listados.

Contraseñas: Argon2id con sal por usuario. Segundo factor: llave de acceso o códigos temporales; nunca SMS.

La bitácora no la reescribe ni quien administra el servidor



Cambiar un registro rompe la cadena. Reescribirla entera no coincide con lo que ya salió.

La bitácora no la reescribe ni quien administra el servidor



Cuatro mecanismos que se apoyan: (1) la aplicación solo puede insertar, no modificar ni borrar; (2) cada registro incluye la huella SHA-256 del anterior; (3) una vez al día la última huella sale del servidor, recibe un sello de tiempo RFC 3161 y va al buzón de la Gerencia y del auditor; (4) la acción y su registro se confirman en la misma transacción.

Qué se registra: autenticación, cambios, consultas de datos sensibles, administración y toda decisión de-negada. Con qué campos: instante, cuenta y rol, acción, objeto y versión, resultado y regla, origen, huellas.

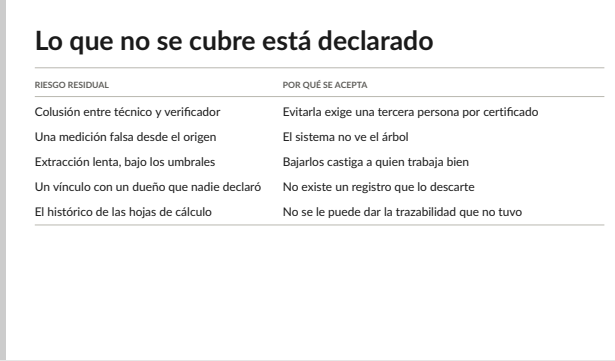
Conservación: diez años para cambios y decisiones, que es la trazabilidad que el cliente debe poder re-construir (minuta, P-18); dos para consultas (supuesto P-19).

Secretos: viven en una bóveda; la llave de sello no sale, se le pide a la bóveda que firme. La bóveda se abre con dos de tres custodios.

Lo que no se cubre está declarado

RIESGO RESIDUAL	POR QUÉ SE ACEPTA
Colusión entre técnico y verificador	Evitarla exige una tercera persona por certificado
Una medición falsa desde el origen	El sistema no ve el árbol
Extracción lenta, bajo los umbrales	Bajarlos castiga a quien trabaja bien
Un vínculo con un dueño que nadie declaró	No existe un registro que lo descarte
El histórico de las hojas de cálculo	No se le puede dar la trazabilidad que no tuvo

Lo que no se cubre está declarado



Lo que no se cubre está declarado

RIESGO RESIDUAL	POR QUÉ SE ACEPTA
Colusión entre técnico y verificador	Evitarla exige una tercera persona por certificado
Una medición falsa desde el origen	El sistema no ve el árbol
Extracción lenta, bajo los umbrales	Bajarlos castiga a quien trabaja bien
Un vínculo con un dueño que nadie declaró	No existe un registro que lo descarte
El histórico de las hojas de cálculo	No se le puede dar la trazabilidad que no tuvo

Son trece riesgos residuales en el documento de arquitectura. Otros: equipo de usuario infectado; el operador puede detener o destruir (se detecta, no se impide); un solo servidor; sin hardware de seguridad dedicado; la fecha de medición es declarada, porque no hay aplicación sin conexión; el proveedor de hospedaje tiene acceso físico; la aprobación no lleva firma digital certificada; y la misma regla vive en dos lugares, el motor y la base.

Si preguntan qué requerimiento quedó sin cubrir: la trazabilidad de diez años hacia atrás. Las hojas de cálculo se congelan, se les calcula la huella y lo migrado queda marcado como histórico.

Antes de entrar en operación hay diez criterios de aceptación, entre ellos una prueba de penetración autorizada por escrito.

El cliente respondió, y el diseño cambió en cinco puntos

	LO QUE RESPONDIÓ	QUÉ CAMBIÓ
P-01	Un verificador puede medir, por excepción	Habilitación temporal; no aprueba lo que midió
P-05	Las fincas las asignan los supervisores	**Rol nuevo: supervisor de campo**
P-06	La revisión sigue después del cierre	El cierre detiene registrar, no aprobar
P-07	Revisión técnica antes de autorizar	Solicitar, corregir, revisar, autorizar
P-10	Avisar primero; no bloquear de inmediato	Aviso, verificación, restricción temporal

Catorce de veintiséis consultas, respondidas por escrito. Las otras doce son supuestos declarados. Minuta: informe de políticas, Anexo A.

El cliente respondió, y el diseño cambió en cinco puntos

El cliente respondió, y el diseño cambió en cinco puntos

	LO QUE RESPONDIÓ	QUÉ CAMBIÓ
P-01	Un verificador puede medir, por excepción	Habilitación temporal; no aprueba lo que midió
P-05	Las fincas las asignan los supervisores	**Rol nuevo: supervisor de campo**
P-06	La revisión sigue después del cierre	El cierre detiene registrar, no aprobar
P-07	Revisión técnica antes de autorizar	Solicitar, corregir, revisar, autorizar
P-10	Avisar primero; no bloquear de inmediato	Aviso, verificación, restricción temporal

Catorce de veintiséis consultas, respondidas por escrito. Las otras doce son supuestos declarados. Minuta: informe de políticas, Anexo A.

Qué decir: el diseño se hizo completo con supuestos declarados, y la consulta sirvió como validación. De catorce respuestas: dos confirmaron el supuesto (P-03, el verificador devuelve y no edita; P-11, el técnico solo ve sus fincas), cuatro lo ajustaron, seis lo cambiaron y dos quedaron a nuestro criterio.

Lo que resistió: la técnica de separación. La respuesta a P-01 no la cambió; solo volvió dinámica la exclusión entre técnico y verificador.

Lo que hubo que rehacer: el orden de la enmienda (P-07), lo que el cierre detiene (P-06) y quién asigna las fincas (P-05). Y el diseño era más estricto de lo que el cliente quería: bloqueaba de inmediato donde bastaba avisar (P-10).

Otros cambios para citar si preguntan: sociedades y representantes como dueños, y declaración de vínculos con abstención (P-15); ninguna norma de auditoría se da por supuesta, y los auditores exportan evidencia sellada (P-18); registro después de la visita, con fecha de medición y fecha de registro (P-22); diseño sin cantidades fijas (P-02).

Cada cambio llegó hasta la matriz: diecisiete casos de prueba nuevos, T-21 a T-37, y cinco modificados.

Cuatro decisiones que el cliente dejó en nuestras manos

LA PREGUNTA	LO QUE DECIDIMOS
¿Revisa un verificador distinto del original?	**Sí, cuando la enmienda es material**
¿Hace falta firma digital certificada?	No: sello de la empresa y comprobación en línea
¿Llaves físicas para todo el personal?	No: llave de acceso del propio equipo
¿Dónde se hospeda y quién lo opera?	Servidor virtual contratado; personal designado

El cliente pidió que cada decisión tenga una justificación clara y responda a un riesgo real, no el sistema más complejo.

Cuatro decisiones que el cliente dejó en nuestras manos

Cuatro decisiones que el cliente dejó en nuestras manos

LA PREGUNTA	LO QUE DECIDIMOS
¿Revisa un verificador distinto del original?	**Sí, cuando la enmienda es material**
¿Hace falta firma digital certificada?	No: sello de la empresa y comprobación en línea
¿Llaves físicas para todo el personal?	No: llave de acceso del propio equipo
¿Dónde se hospeda y quién lo opera?	Servidor virtual contratado; personal designado

El cliente pidió que cada decisión tenga una justificación clara y responda a un riesgo real, no el sistema más complejo.

Verificador distinto (minuta, P-07): tres opciones. Siempre distinto: toda corrección, hasta una de forma, espera a otra persona. El mismo: quien aprobó el dato erróneo dictamina sobre su propio error. Elegimos según lo que cambia: es material si cambia un dato del cálculo de toneladas o si ya hay un certificado; entonces revisa otro. Lo determina el sistema, no una persona.

Firma digital (P-04): la firma certificada de cada verificador da autenticidad y autoría con presunción legal, pero no dice si el certificado fue revocado después, y cuesta por persona. Elegimos sello de la empresa, comprobación en línea por código y aprobación personal con segundo factor, que queda en la bitácora.

Llaves físicas (P-23): no hay presupuesto para todos. La llave de acceso del propio dispositivo (passkey) resiste igual el correo falso y no cuesta nada. Se recomiendan llaves físicas solo para Gerencia, administrador, operador y custodios de la bóveda.

Hospedaje (P-23): servidor propio, servidor virtual contratado o servicios administrados, con los cuatro criterios del cliente. El propio exige inversión y cuidar energía y enlace en una oficina rural; los administrados no son software libre. Lo cotidiano está automatizado.

Referencias principales

Abadi, M., & Fournet, C. (2003). Access control based on execution history. *NDSS*.

Clark, D. D., & Wilson, D. R. (1987). A comparison of commercial and military computer security policies. *IEEE S&P*.

Kuhn, D. R., Coyne, E. J., & Weil, T. R. (2010). Adding attributes to role-based access control. *Computer*, *43*(6).

Li, N., Tripunitara, M. V., & Bizri, Z. (2007). On mutually exclusive roles and separation-of-duty. *ACM TISSEC*, *10*(2).

Saltzer, J. H., & Schroeder, M. D. (1975). The protection of information in computer systems. *Proc. IEEE*, *63*(9).

Sandhu, R. S., Coyne, E. J., Feinstein, H. L., & Youman, C. E. (1996). Role-based access control models. *Computer*, *29*(2).

Schneier, B., & Kelsey, J. (1999). Secure audit logs to support computer forensics. *ACM TISSEC*, *2*(2).

Simon, R. T., & Zurko, M. E. (1997). Separation of duty in role-based environments. *CSFW*.

Temoshok, D., et al. (2025). *Digital identity guidelines: Authentication and authenticator management* (NIST SP 800-63B-4).

Ley N.° 8968 (2011) y su reglamento, Decreto N.° 37554-JP. Ley N.° 7975 (2000). Ley N.° 8454 (2005). Ley N.° 9048 (2012).

ISO/IEC 17029:2019. ISO 14065:2020. ISO/IEC 27001:2022.

Vargas Rivera, A. (2026). *Material de estudio del curso CE-1115 y enunciado del proyecto, parte 1*. ITCR.

Referencias principales

Referencias principales

Abadi, M., & Fournet, C. (2003). Access control based on execution history. *NDSS*.

Clark, D. D., & Wilson, D. R. (1987). A comparison of commercial and military computer security policies. *IEEE S&P*.

Kuhn, D. R., Coyne, E. J., & Weil, T. R. (2010). Adding attributes to role-based access control. *Computer, 43*(6).

Li, N., Tripunitara, M. V., & Bizri, Z. (2007). On mutually exclusive roles and separation-of-duty. *ACM TISSEC, 10*(2).

Saltzer, J. H., & Schroeder, M. D. (1975). The protection of information in computer systems. *Proc. IEEE, 63*(9).

Sandhu, R. S., Coyne, E. J., Feinstein, H. L., & Youman, C. E. (1996). Role-based access control models. *Computer, 29*(2).

Schneier, B., & Kelsey, J. (1999). Secure audit logs to support computer forensics. *ACM TISSEC, 2*(2).

Simon, R. T., & Zurko, M. E. (1997). Separation of duty in role-based environments. *CSFW*.

Temoshok, D., et al. (2025). *Digital identity guidelines: Authentication and authenticator management* (NIST SP 800-63B-4).

Ley N.° 8968 (2011) y su reglamento, Decreto N.° 37554-JP. Ley N.° 7975 (2000). Ley N.° 8454 (2005). Ley N.° 9048 (2012).

ISO/IEC 17029:2019. ISO 14065:2020. ISO/IEC 27001:2022.

Vargas Rivera, A. (2026). *Material de estudio del curso CE-1115 y enunciado del proyecto, parte 1*. ITCR.

La lista completa, en formato APA, está en cada uno de los cinco documentos.